SECURITY NINJA GERMANY



Beyond Secrets

Securing Workload Identities in Entra ID



Session

How well are your non-human identities actually secured? In most tenants: not well enough.

#SecNinjas

Thank you to our Sponsors!

Host Partner

Microsoft

Gold

glueck kanja

water IT Security & Defense

robopack

PROACT

Silver

WORKSIMPLE EINFACH ARBEITEN

semperis

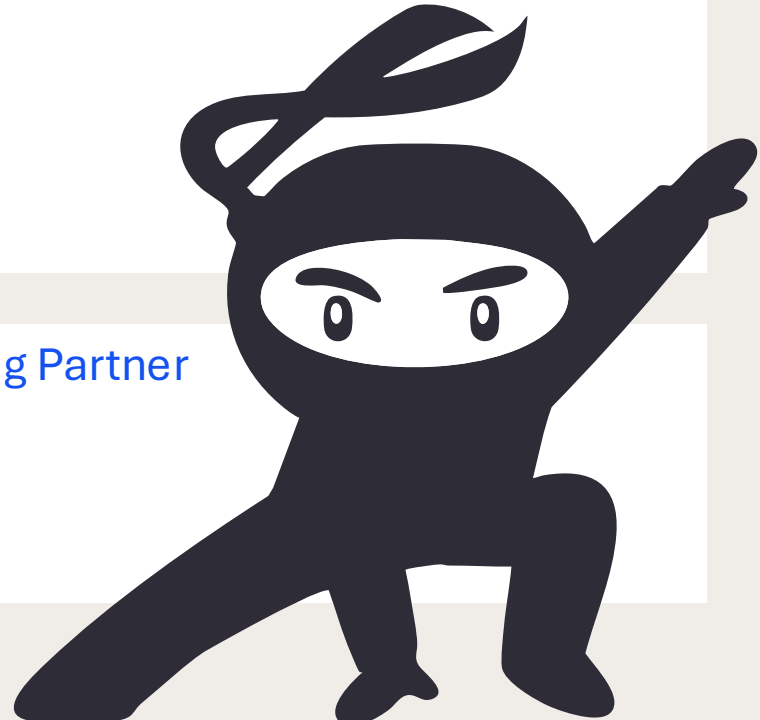
Bronze

ugurlabs

IC CONSULT

Snacks & Networking Partner

SCE



About Daniel

SECURITY NINJA GERMANY

💼 Day job

Lead Architect AI Endpoint & Security

baseIT, Austria

🎯 Focus

Entra ID, Intune

AVD, Windows 365

Endpoint security

✍️ Blog

headsinthecloud.blog

Entra and Intune deep dives

Free tools on GitHub



🎓 Certifications

A few Microsoft certs

A lot more customer hours

🏡 Off duty

👦👶 Two boys, 3 years and 1.5 months

🔧 House, garden, workshop

🍺 Home brewing

💬 Contact

LinkedIn · Daniel Fraubaum

GitHub · daniel-fraubaum

Agenda

SECURITY NINJA GERMANY

Beyond Secrets

Securing Workload Identities in Entra ID

Foundations

App registration, service principal, managed identity, agent identity

Hidden secrets

Credentials added via Graph that the admin center never shows

App Management Policies

Block secret creation tenant-wide and per app

Conditional Access

Pin workload identities to known network locations

Where to start

Seven things for your own tenant, in this order

The identities nobody really owns

›››

Two kinds of identity in every tenant

SECURITY NINJA GERMANY

Human identities

- Employees
- Partners and guests
- Admins

Non-human identities

- Applications and services
- Automation and pipelines
- Managed identities
- Agents

Both sign in. Only one side has MFA, an owner and a lifecycle. This talk is about the other one.

Four names, constantly confused

SECURITY NINJA GERMANY

App Registration

- The template: application object
- Lives once, in the home tenant
- Defines permissions and credential rules

Service Principal

- The instance of that app in a tenant
- This is what actually signs in
- Holds the granted permissions

Enterprise Application

- Not a separate object
- The portal name for the service principal

Managed Identity

- A service principal, managed by Azure
- No credential you ever see or rotate

Two objects, two credential stores

One app registration creates one service principal per tenant. Both hold credentials.

App Registration

application object

- Credentials: passwordCredentials, keyCredentials
- Portal: Certificates & secrets
- **Visible**

creates



Service Principal

servicePrincipal object, "Enterprise application"

- Credentials: its own passwordCredentials, keyCredentials
- Portal: no blade at all
- **Invisible**

Same app, two credential lists. The portal shows you one of them. Part 2 lives in the other.

Managed Identities: credentials you never touch

SECURITY NINJA GERMANY

System-assigned

- Tied to one Azure resource
- Deleted with it

User-assigned

- Standalone resource
- Attach it to many workloads

- **No secrets or certificates**
- **Rotated automatically by Azure**
- **Your default for Azure workloads**

No secret does not mean no risk: audit what they are allowed to do (MIRA on whennotif.io does that in the browser).

Where the real power sits

SECURITY NINJA GERMANY

Delegated: the app acts as a signed-in user

- Acts as the signed-in user
- Bound by that user's Conditional Access
- MFA and sign-in risk still apply

Application: the app acts on its own

- No user context at all
- Not protected by MFA
- Excluded from sign-in risk
- Often tenant-wide and long-lived

An app with application permissions can out-power any admin, and nobody is watching it

`Sites.FullControl.All` `Mail.ReadWrite` `Directory.ReadWrite.All` `Files.ReadWrite.All`

Agents are workload identities, too

Every agent signs in as a service principal. Entra calls the new ones agent identities.

- **Copilot Studio: identity created by the maker, not by you**
- **Foundry: credentials live on the blueprint, client secret possible**
- **Classic agents: plain service principals, often without an owner**
- **Inventory: Entra ID > Agents, or Graph by tag**

Same credentials, same permissions, same attack surface. Everything that follows applies to agents too.

Conditional Access for agents: preview, licensed through Microsoft Agent 365.

SECURITY NINJA GERMANY

The credential that hides in plain sight

›››

Invisible by design

SECURITY NINJA GERMANY

Entra admin center

Certificates & secrets

Certificates	0
Client secrets	0
Federated credentials	0

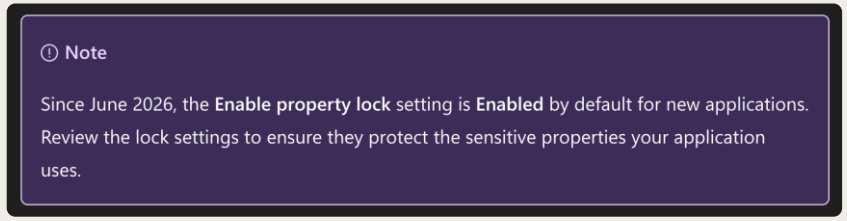
Looks perfectly clean.

Microsoft Graph

```
GET /servicePrincipals/{id}
    ?$select=displayName,passwordCredentials

{
  "displayName": "SecNinjasGermany",
  "passwordCredentials": [
    {
      "keyId": "7f53c8f0-6083-441b-849b-...",
      "displayName": null,
      "hint": "abc",
      "startDateTime": "2026-10-16T06:44:21Z",
      "endDateTime":   "2028-10-16T06:44:21Z"
    }
  ]
}
```

A secret is right there.



A secret added to the service principal through Graph never shows up on this blade. The catch: the app instance property lock blocks exactly this call. Default for portal-created apps since 2023, for every new app since June 2026. Older ones: usually off.

SECURITY NINJA GERMANY

● LIVE DEMO

The secret the portal never shows

- SecNinjasGermany in the admin center: 0 secrets, 0 certificates
- addPassword on its service principal, straight through Graph
- Back in the admin center: still nothing
- Sign in with that secret. It just works.
- One Graph query over every service principal finds them all

All the ways a secret gets created

SECURITY NINJA GERMANY

Where it comes from

- Admin center, application object only
- Any API client: Graph, PowerShell, Azure CLI, SDKs
- Infrastructure as code and pipelines
- Your coding agent, trained on years of secret examples

Who can do it

- App owners: any user, no admin role
- Application, Cloud Application, Global Administrator
- Custom roles with credentials/update
- Apps holding Application.ReadWrite.All or OwnedBy

Every user may register apps. Owner means credential rights. Nobody reviews owners.

`Users can register applications: Yes` `Owners` `Application.ReadWrite.All` `credentials/update`

SECURITY NINJA GERMANY

A leaked secret needs nothing else

- Authenticates from anywhere
- No user sign-in required
- No Conditional Access stops it, by default
- No MFA challenge is ever raised

SECURITY NINJA GERMANY

A few days ago

- Vendor app with application permissions, one stolen credential
- Sign-ins into ~1,000 tenants, 300 of them successful
- Persistence: new secrets on other trusted apps, Global Admin
- Responders recommend: AMP, fewer app admins, CA for workload identities, ID Protection

Source: ConnectWise advisory, Huntress and The Hacker News, 18 October 2026. The rest of this talk is that last line.

SECURITY NINJA GERMANY

Block it at the source

›››

App Management Policies

SECURITY NINJA GERMANY

Tenant default policy

- One baseline for every app and service principal
- Roll out with restrictForAppsCreatedAfterDateTime: new apps only

Per-application policy

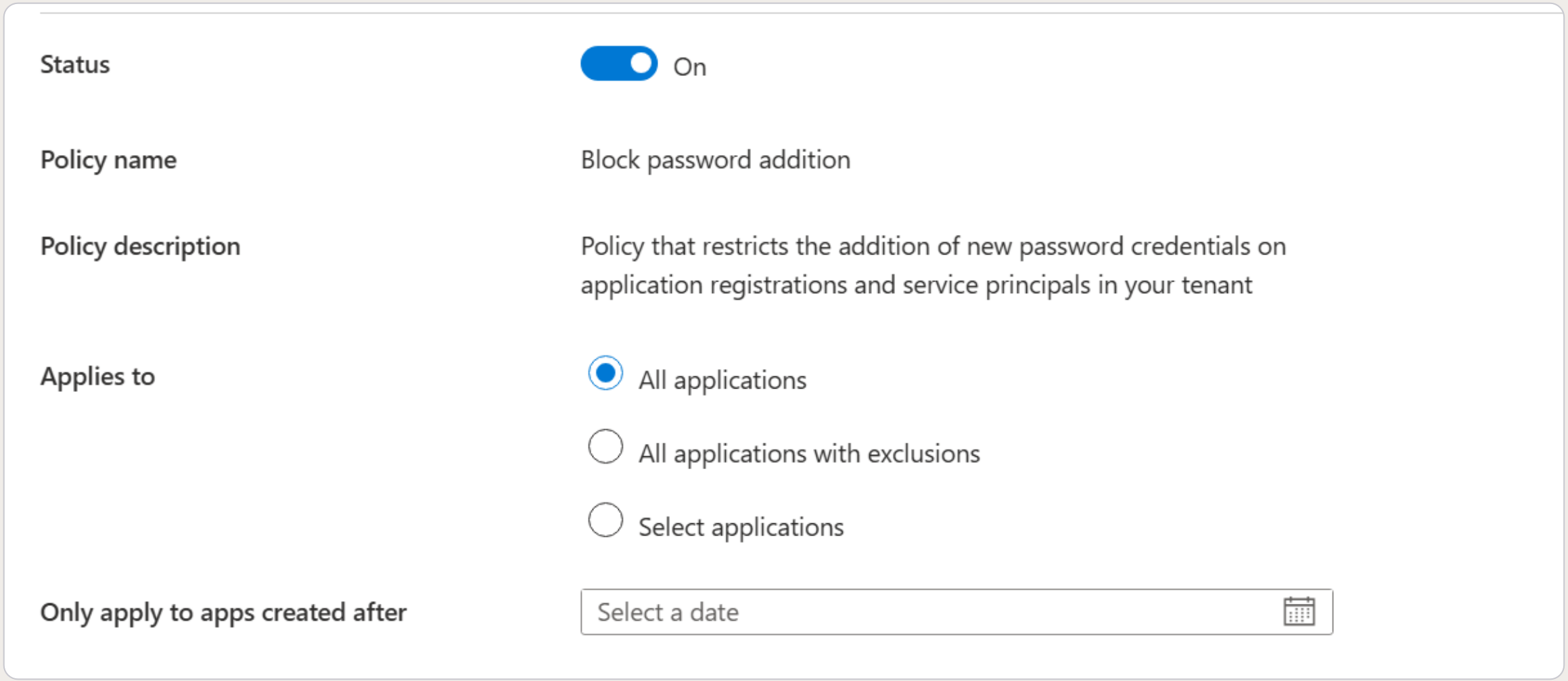
- Stricter or looser for single apps
- Exceptions via custom security attributes

What you can restrict

- Block new client secrets (password credentials)
- Cap credential lifetimes
- Require certificates or federated credentials instead
- Apply only to apps created after a chosen date

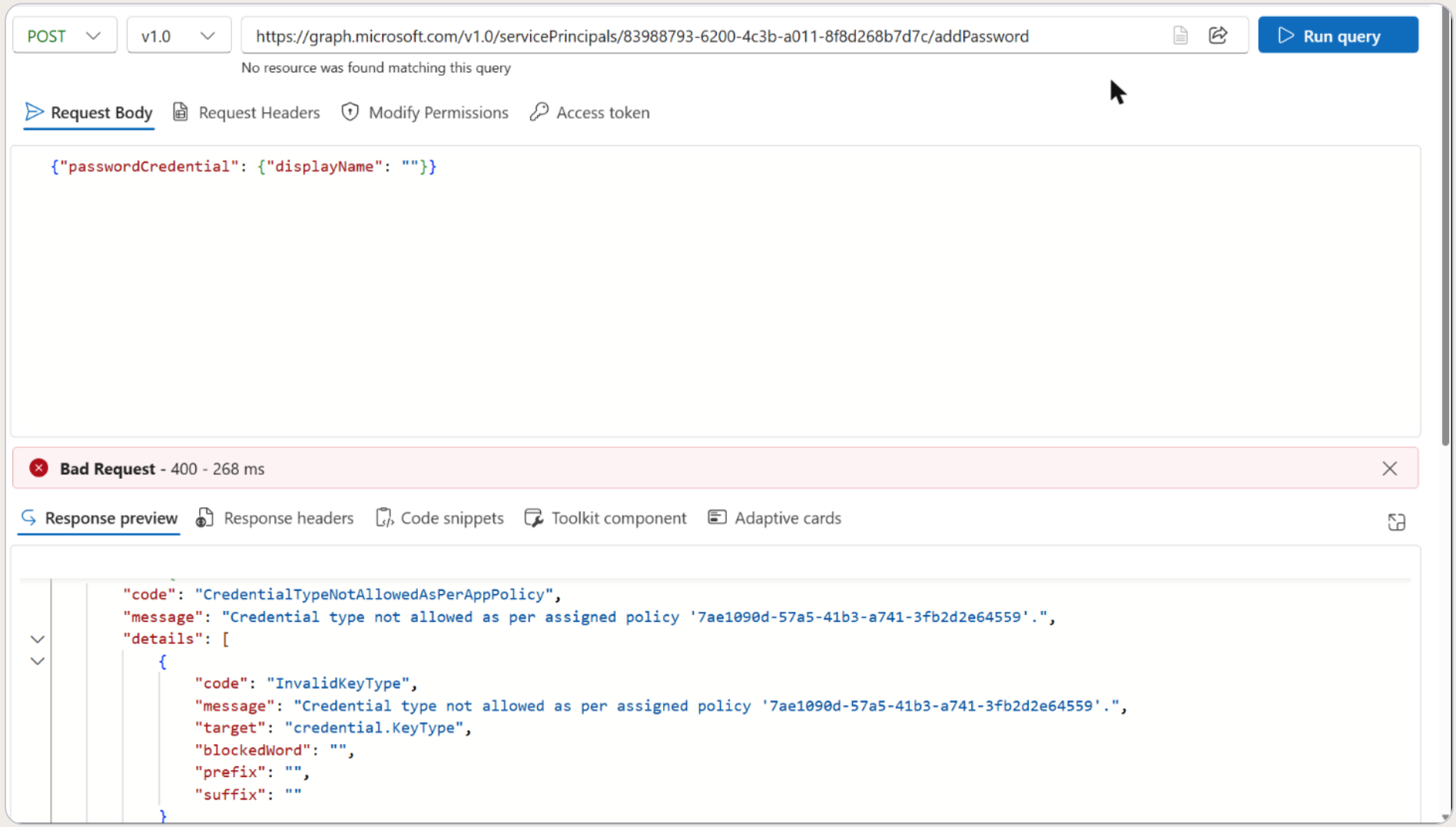
Included in Entra ID Free. Graph, or Enterprise applications > Application policies.

One switch, tenant-wide



Enterprise applications > Application policies > Block password addition. Scope it, or limit it to apps created after a date.

Same call, now refused



The exact addPassword call from Demo 1. 400 Bad Request: credential type not allowed as per assigned policy.

SECURITY NINJA GERMANY

Controlling where they authenticate from

›››

Workload identities don't move

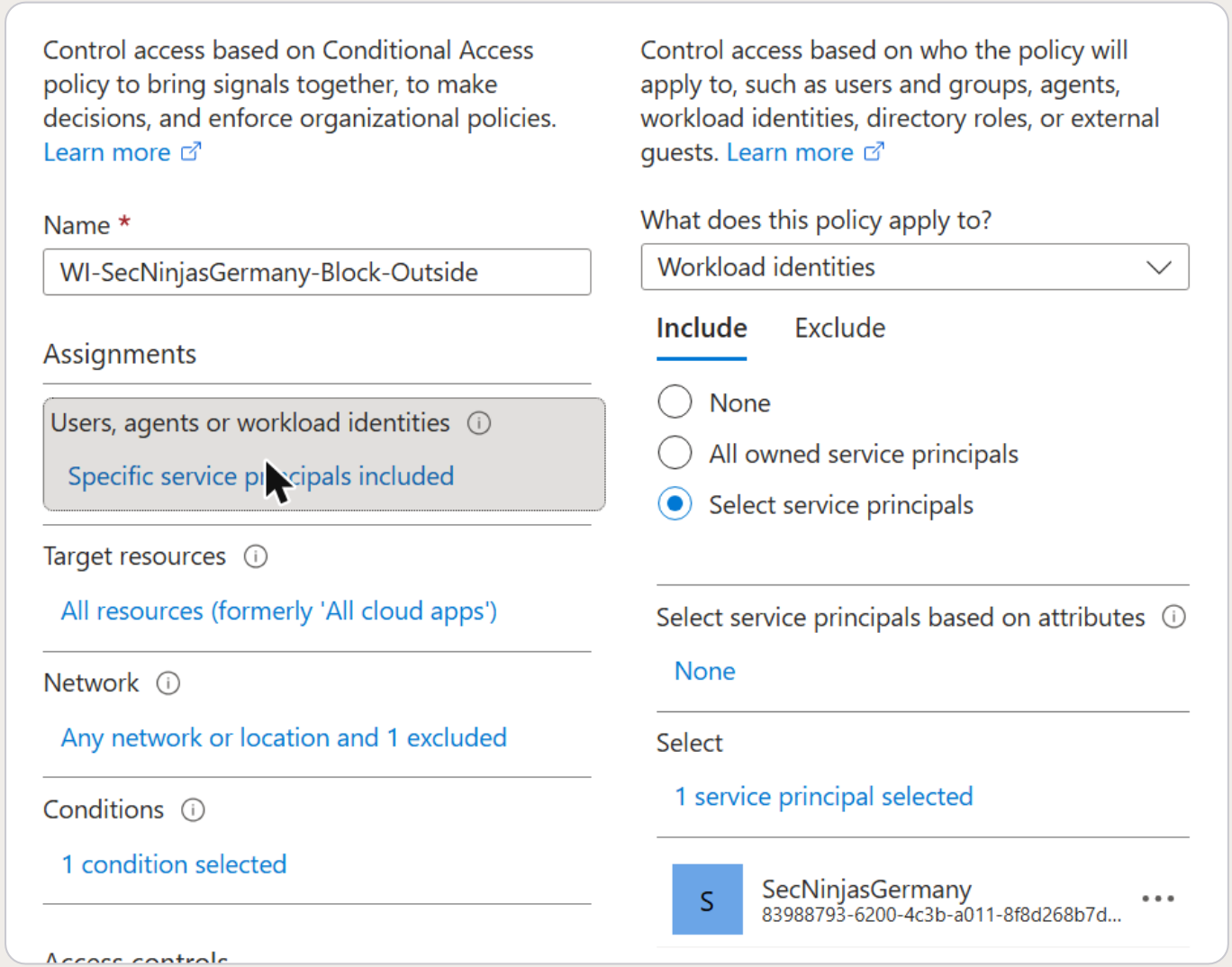
Unlike users, their network origin is predictable. Conditional Access has two levers for them: location and risk. Location first.

- **On-premises servers**
- **Azure workloads**
- **Automation platforms**
- **SaaS with static IPs**

Allow authentication only from trusted IP ranges. A leaked secret alone is then no longer enough.

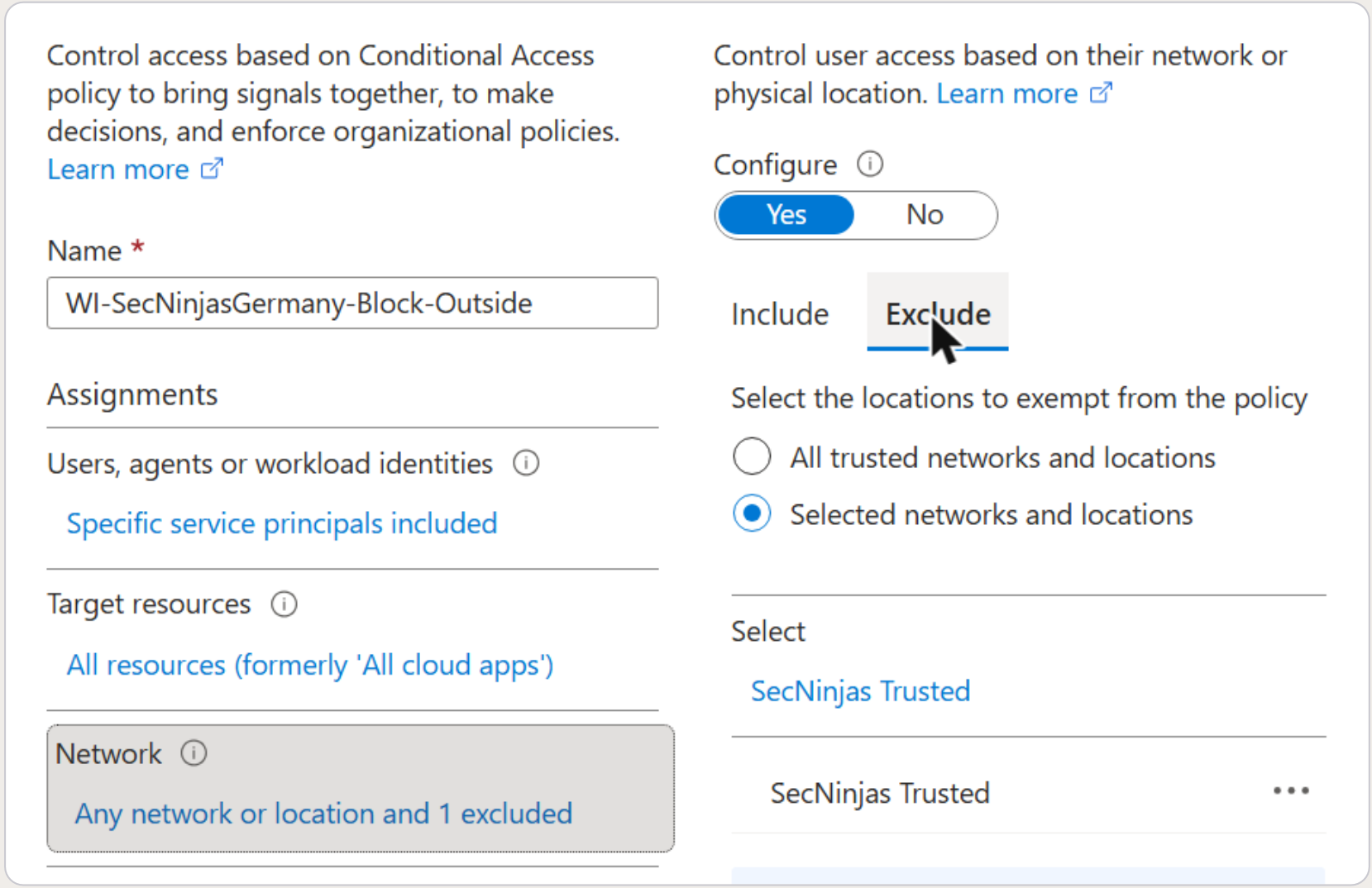
Three things to know: these policies cover authentications in your own tenant only, not multi-tenant apps signing in from a foreign tenant. Named-location policies do not apply to managed identities. And agent identities are a separate type with their own Conditional Access (preview), scoped per agent or per blueprint and licensed through Microsoft Agent 365.

Step 1: assign the workload identity



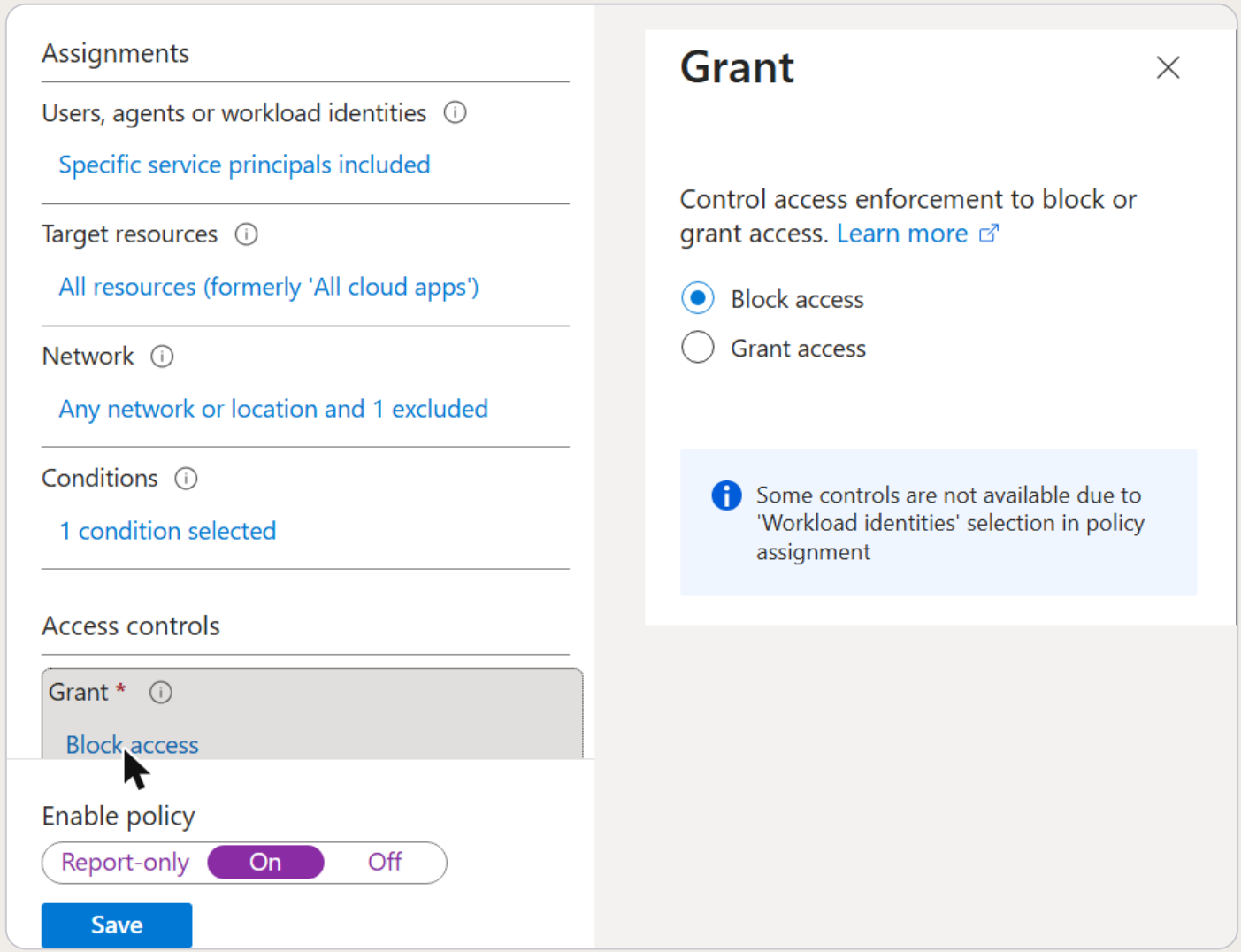
Conditional Access policy, Assignments: Workload identities, select service principals, SecNinjasGermany.

Step 2: exclude the trusted network



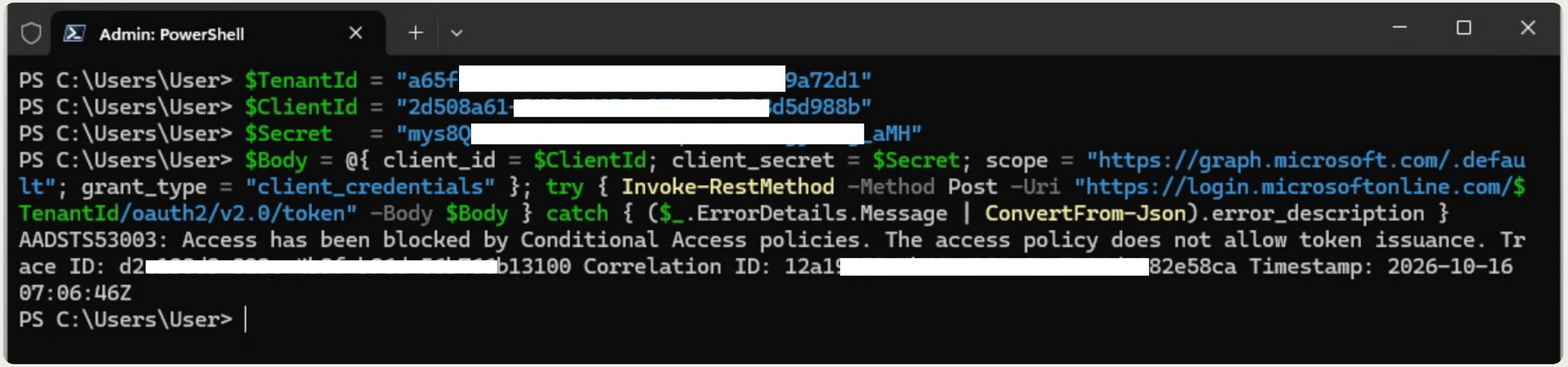
Network: any location included, the named location SecNinjas Trusted excluded.

Step 3: Block access, switch on



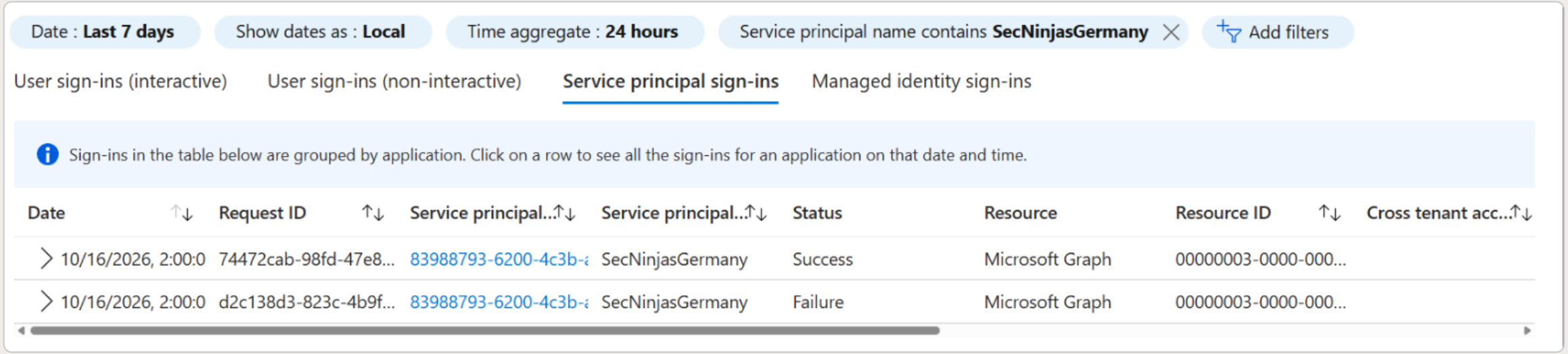
Grant: Block access. Enable policy: On. Report-only first if you want to watch the sign-in log for a week.

Wrong network, no token



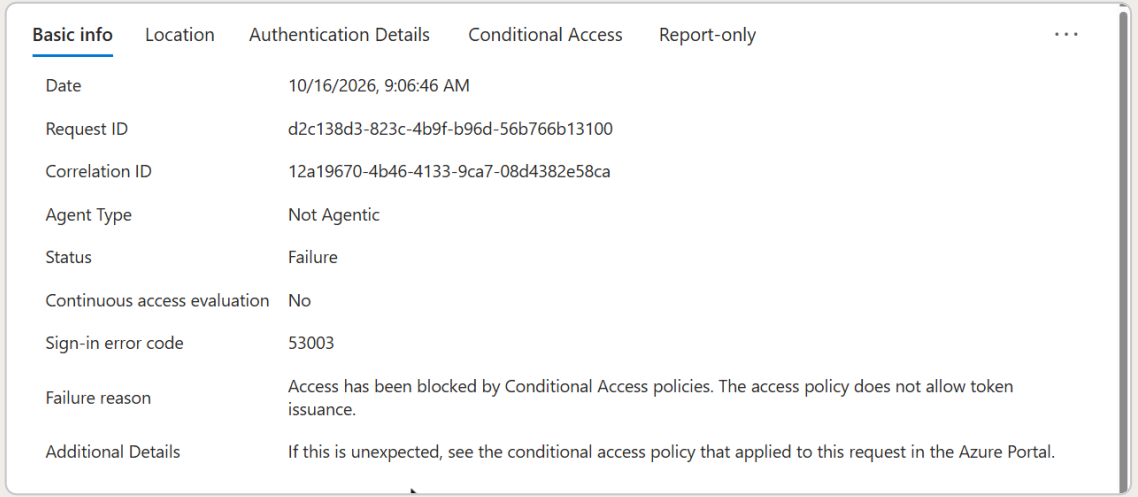
Client credentials flow with a valid secret, from a laptop outside the named location. Entra answers with AADSTS53003: access has been blocked by Conditional Access policies. The secret is intact and useless.

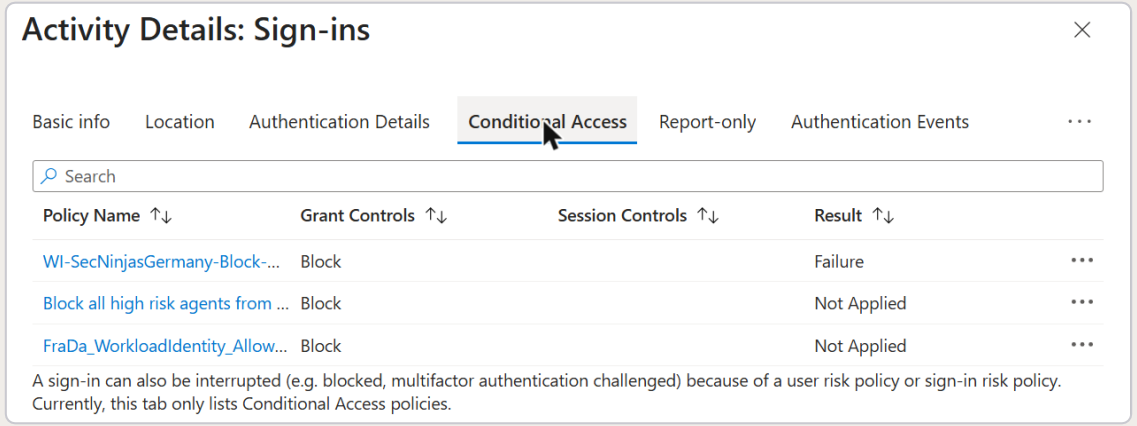
Same app, with and without the policy



Service principal sign-ins, filtered to SecNinjasGermany. Success with the policy off, Failure with the policy on.

The sign-in log names the policy





Left: error code 53003, blocked by Conditional Access. Right: the Conditional Access tab, our policy with result Failure.

One policy, three parts

Assignments	Conditions	Access controls
Workload identities **SecNinjasGermany** One app, no broad scoping	Network: any location **Exclude: SecNinjas Trusted** Your known IP ranges, nothing else	Grant **Block access** Everything outside the trusted range

Report-only first, then enforce. One policy per privileged app keeps the audit trail clean.

Lever two: risk

Signal	Policy	Needs
Entra ID Protection **Leaked credentials** Secret found on GitHub, unusual sign-in, suspicious admin change	Condition **Service principal risk** Medium and above, same policy pattern	License **Workload ID Premium** The $3 SKU. Per app, only the ones you protect

Location says where the app may come from. Risk says whether it still should, even from the right place.

SECURITY NINJA GERMANY

The cost objection doesn't hold

$3

per app · per month

Licensed per app, not per user

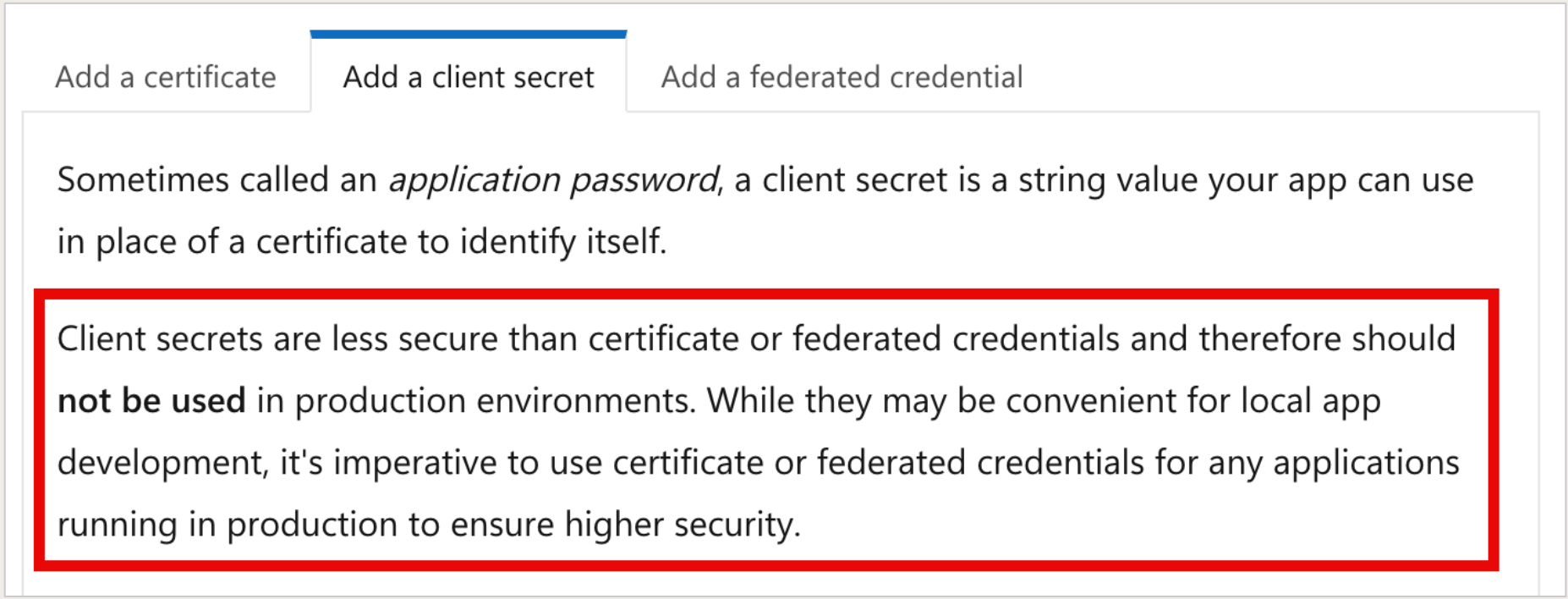
Buys you service principal risk in CA

Agents: separate SKU, Microsoft Agent 365

For an app with tenant-wide write access, that is nothing next to the blast radius of its abuse.

Don't take my word for it

Microsoft Learn on client secrets: development and testing only, never production.



Microsoft glueckkanja water IT Security & Defense robopack PROACT
WORKSIMPLE EINFACH ARBEITEN semperis ugurlabs IC CONSULT

Make secrets the exception

SECURITY NINJA GERMANY

1st choice
Managed Identities

- Anything in Azure
- On-prem via Azure Arc
- Nothing to steal

2nd choice
Federated credentials

- GitHub Actions, AWS, GCP, Kubernetes
- Even the Claude API
- Short-lived token, nothing stored

3rd choice
Certificates

- Only if you must hold a credential
- Beats a client secret
- Secrets come dead last

A client secret is a documented exception, never the default. Microsoft says the same.

Where to start

SECURITY NINJA GERMANY

1. Run the Graph query over every service principal. The portal blade is not an inventory.
2. Delete what nobody uses. Entra recommendations list unused apps and credentials for free.
3. Review app owners. Owning an app means being able to add a credential to it.
4. Enable the app instance property lock on every existing app registration. Default only since June 2026.
5. Enable the default App Management Policy for apps created after today.
6. Move to managed identities and federated credentials, starting with the apps that can read mail.
7. Put every app with write permissions behind a named-location Conditional Access policy.

Consentra: consent inventory

What	How	Output
Every OAuth consent **Admin and user** Microsoft, tenant-owned or third party, risky scopes flagged, hidden apps included	Browser or PowerShell **Read-only Graph** Directory.Read.All and Application.Read.All, nothing is changed	HTML dashboard + CSV **Filter by risk and vendor** Search, per-app detail with publisher, scopes and user count, CSV for your SIEM

Consentra, free, by Jürgen Waldl: whennotif.io/tools/consentra in the browser, github.com/waljue/Consentra as PowerShell. The list you need before you touch any vendor app.

SECURITY NINJA GERMANY

Questions?

Daniel Fraubaum

headsinthecloud.blog

linkedin.com/in/daniel-fraubaum-b352ba1aa · github.com/daniel-fraubaum



Thank You, Ninjas!

